Microsoft Defender for Cloud

Implementation Solution Guide

Version 1.0.0 · 2026-07-11

Contents

Executive Summary — Microsoft Defender for Cloud 5

What this is . . . 5

The outcome . . . 5

The boundary . . . 5

Effort and approach . . . 6

1. Solution Overview — Microsoft Defender for Cloud 6

What Microsoft Defender for Cloud is . . . 6

What this solution is (and how it is structured) . . . 6

How the technology works (the levers you design and pull) . . . 7

The standard deployment model . . . 7

Scope (what this solution produces) . . . 8

What is out of scope (and where it lives) . . . 8

Connections and authentication used . . . 8

2. Requirements Guide — Microsoft Defender for Cloud 9

2.1 A management-group hierarchy and a pilot scope . . . 9

2.2 A deployment identity with management-group rights . . . 9

2.3 Resource providers registered . . . 10

2.4 Plan-enablement decision (which plans, which waves) and cost approval . . . 10

2.5 Agents/extensions provisioning for Servers . . . 10

2.6 Log Analytics workspace and SIEM target for continuous export . . . 10

2.7 Alert-tuning plan and a notify-first response workflow . . . 10

2.8 A pilot subscription with Secure Score populated (for enablement labs) . . . 11

2.9 Attendee/facilitator access and workstation tooling (for the labs) . . . 11

2.10 Multicloud inputs (AWS/GCP, if in scope) . . . 11

2.11 A pilot resource group and evaluation criteria (for the PoC) . . . 11

2.12 Change control, pilot scope, and rollback . . . 12

Checklist . . . 12

Global Requirements — Defender (category-level) 12

G1. Microsoft 365 / Entra tenant . . . 12

G2. Defender licensing . . . 13

G3. Administrative roles (least privilege) . . . 13

G4. Onboarding reach to endpoints / identity / workloads . . . 13

G5. Network access to Defender service endpoints . . . 13

G6. A pilot ring . . . 13

G7. Log Analytics workspace (where required) . . . 13

G8. Response governance . . . 14
3. Implementation Guide — Microsoft Defender for Cloud 14
Naming (set once, reuse verbatim) . . . 14
Phase A — Architect (design + reference Bicep) 15
Step A1 — Assess: map the estate, current state, and cost inputs . . . 15
Step A2 — Design: produce the reference architecture and decision record . . . 15
Step A3 — Pilot deploy: enable plans on the pilot scope (what-if first) . . . 16
Step A4 — RBAC and governance on the pilot . . . 16
Phase B — Protect (workload protection plans / CWPP) 16
Step B1 — Enable the workload plans on the pilot subscription . . . 16
Step B2 — Wire Defender for Servers (MDE + agents) . . . 16
Step B3 — Configure continuous export . . . 17
Step B4 — Tune alerts (suppression + notifications) . . . 17
Step B5 — Add a notify-only response workflow . . . 17
Phase C — Enable the team (labs, runbook, knowledge-check) 17
Lab 0 — Readiness check (Assess) . . . 18
Lab 1 — Secure Score & recommendations . . . 18
Lab 2 — Workload-protection alerts . . . 18
Lab 3 — Regulatory compliance . . . 19
Lab 4 — Multicloud connectors . . . 19
Lab 5 — Remediation cadence & reporting (preview-first) . . . 19
Wrap-up . . . 20
Phase D — Prove value (guided, benign proof-of-concept) 20
Step D1 — Assess readiness (read-only) . . . 20
Step D2 — Enable CSPM + one workload plan on the pilot subscription . . . 20
Step D3 — Generate benign test signal . . . 20
Step D4 — Validate and demonstrate the detections . . . 21
Step D5 — Score against your criteria . . . 21
Step D6 — Tear down (clean rollback + stop billing) . . . 21
Expand (across the hierarchy and multicloud) 22
5. Testing Guide — Microsoft Defender for Cloud 22
Part A — Architect (Phase A) . . . 23
Part B — Protect (Phase B) . . . 23
Part C — Enable the team (Phase C) . . . 24
Part D — Prove value (Phase D PoC) . . . 25
6. Troubleshooting Guide — Microsoft Defender for Cloud 26

Phase A — Architect . . . 26
Phase B — Protect . . . 27
Phase C — Enable the team . . . 28
Phase D — Prove value (PoC) . . . 28
All phases — script/auth . . . 29
7. Best Practices — Microsoft Defender for Cloud 29
Design before you deploy — and keep the decision record . . . 29
Enable at management-group scope, not subscription by subscription . . . 29
Deploy what-if first, always; treat the Bicep as a reference to adapt . . . 29
Treat cost as a first-class decision, and name a budget owner . . . 30
Pair CWPP with CSPM, don't substitute — cross-reference the posture solution . . . 30
Provision the Servers agents properly . . . 30
Tune alerts so the SOC trusts them; keep response notify-first . . . 30
Export once, centrally, to the SIEM . . . 30
Make governance and exemptions explicit . . . 30
Train against the pilot, preview-first; and prove value benignly . . . 31
Add multicloud after the Azure pilot is solid . . . 31
Defer the decisions to the owners . . . 31
Where to go next . . . 31
8. Deliverables Summary — Microsoft Defender for Cloud 32
Documentation (source/) . . . 32
Scripts (scripts/) . . . 32
Package . . . 33
Appendix A — PowerShell Scripts 34

Executive Summary — Microsoft Defender for Cloud

What this is

The **complete Microsoft Defender for Cloud (MDC) solution** — a single, end-to-end package that takes Defender for Cloud from a blank estate to a designed, workload-protected, team-run cloud security capability. It covers the whole lifecycle in four phases:

1. **Architect** — a reference design for MDC at scale: the management-group onboarding model, plan

strategy and rollout waves, multicloud (AWS/GCP) connectors, RBAC and governance, continuous export/SIEM integration, a cost model, and a deployable reference **Bicep** skeleton.

1. **Protect (workload protection plans)** — enable and tune the **CWPP** plans — Defender for Servers,

Containers, Databases, Storage, Key Vault, App Service, Resource Manager — with MDE integration, continuous export, alert tuning, and a notify-first response workflow.

1. **Enable the team** — five hands-on labs plus a take-home runbook and knowledge-check that make

your admins and SOC/cloud engineers confident operators of MDC.

1. **Prove value** — a guided, benign, reversible proof-of-concept that shows MDC surfacing *your*

misconfigurations and threats, with a scorecard and a teardown that disables paid plans to stop billing.

The outcome

A Defender for Cloud deployment that is **designed** (not ad-hoc, drift-prone per-subscription enablement), **protecting the workloads that matter** (CWPP on, tuned, and exported to the SIEM), **run by a team that knows how**, and **proven** to leadership with evidence from your own tenant.

The boundary

- **Posture remediation is a cross-reference, not a duplicate.** Driving Secure Score, working the

recommendation backlog, agentless scanning, attack-path analysis, and the CSPM remediation cadence at scale are the job of the catalog's **Microsoft Defender for Cloud — CSPM & Secure Score Remediation** solution. This solution *architects the platform* posture runs on, *protects the workloads*, *trains the team*, and *proves the value* — and references CSPM where posture is read.

- **Paid-plan cost and licensing are always "verify."** Defender CSPM and every workload plan are paid

and priced per resource/node/transaction; plan tiers and availability change. Every price/plan statement here is indicative — *verify current pricing and availability in your tenant.*

- **Governance decisions stay with the owners.** Which regulatory standards apply, whether an exemption

or a cost is acceptable, remediation and incident-response approval, and production change control are the customer's compliance / finance / security / operations determinations. This package delivers the technical build, not the decision.

Effort and approach

A competent cloud/security admin can run this without a consultant. Every phase follows the same repeatable model — **Assess** → **Configure** → **Pilot** → **Validate** → **Expand** — with explicit pass/fail gates. Everything disruptive is **pilot-first and preview-first**: IaC deploys `what-if` **first**, plan enablement and PoC changes are `-WhatIf`**-gated and cost-gated**, and the response workflow starts **notify-only**. Delivered as a Word document and PDF plus seven ready-to-run scripts (PowerShell/Az, KQL, and the reference Bicep) in a single ZIP.

1. Solution Overview — Microsoft Defender for Cloud

What Microsoft Defender for Cloud is

Microsoft Defender for Cloud (MDC) is Azure's cloud security service, managed from the **Azure portal** (`portal.azure.com → Microsoft Defender for Cloud`), with alerts surfacing into the unified Defender portal at `security.microsoft.com`. It has two layers:

- **CSPM (Cloud Security Posture Management)** — continuously assesses cloud resource configuration

against a security baseline and expresses the result as a single **Secure Score**, a prioritized list of **recommendations**, an **asset inventory**, and a **regulatory-compliance** view. **Foundational CSPM** is free and on by default for Azure subscriptions; the paid **Defender CSPM** plan adds agentless scanning, attack-path analysis, and cloud-security-graph risk hunting. *Verify current availability in your tenant.*

- **CWPP (Cloud Workload Protection Platform)** — the **paid, per-resource** workload protection plans

(Defender for Servers, Containers, Databases, Storage, Key Vault, App Service, Resource Manager, and more) that actively detect threats against running workloads and raise **security alerts**.

MDC also connects **AWS accounts and GCP projects** via **multicloud connectors**, so one Secure Score, one recommendation list, and one compliance view can span clouds. Its data flows into Defender XDR incidents and can be **continuously exported** to a Log Analytics workspace / Microsoft Sentinel.

What this solution is (and how it is structured)

This is the **complete Defender for Cloud solution** — it delivers the whole lifecycle as four integrated phases, each building on the last:

- **Phase A — Architect.** A reference **design** for MDC across a large, multi-subscription, multicloud

estate: the **management-group onboarding model** (enable at MG scope so every current and future subscription inherits protection), the **plan-enablement strategy** and rollout **waves**, the **multicloud connector design**, the **RBAC and governance model**, the **continuous-export / SIEM integration**, a **cost model**, and a deployable reference `main.bicep` skeleton.

- **Phase B — Protect (workload protection plans / CWPP).** Turn on and **tune** the workload plans on a

pilot subscription, wire the **Defender for Endpoint** integration for Servers, configure **continuous export**, tune alerts with scoped suppression and notifications, and add a **notify-first response workflow**.

• **Phase C — Enable the team.** Five hands-on **labs**, a take-home runbook, and a knowledge-check that

make admins and SOC/cloud engineers confident operators — reading Secure Score and recommendations, triaging workload alerts, reading compliance, understanding connectors, and running a preview-first cadence.

• **Phase D — Prove value.** A guided, **benign, reversible proof-of-concept** on one pilot subscription

that demonstrates MDC surfacing your misconfigurations and threats, scored against your criteria, and torn down cleanly (disabling paid plans to stop billing).

Posture remediation is cross-referenced, not duplicated. Working Secure Score, the recommendation backlog, agentless scanning, and the CSPM remediation program at scale are the catalog's **Microsoft Defender for Cloud — CSPM & Secure Score Remediation** solution. This solution *architects the platform* that CSPM runs on, *protects the workloads*, *trains the team*, and *proves the value* — and references CSPM wherever posture is read.

How the technology works (the levers you design and pull)

• **Management-group scope + inheritance.** Defender plans can be set at a **management group**, and

descendant subscriptions **inherit** the setting — the way to get consistent coverage without touching every subscription and to protect new subscriptions the day they are created. **Azure Policy** (the Microsoft cloud security benchmark initiative and the plan-configuration initiative) is the enforcement mechanism; the reference Bicep drives it.

• **Plans, enabled independently.** Foundational CSPM (free) plus **Defender CSPM** and each **workload

plan** (paid) are enabled per scope and per wave — the strategy decides which, where, and when.

• **Servers + Defender for Endpoint.** Defender for Servers detection uses the **MDE** sensor and the

monitoring agent, auto-provisioned; non-Azure servers join via **Azure Arc**. *Verify current agent/extension requirements.*

• **Continuous export** streams recommendations, Secure Score, and alerts to a workspace and onward to

the SIEM for trending, hunting, and correlation.

• **Alert tuning and response** — scoped suppression rules and notification thresholds make the alert

queue signal, not noise; a **workflow automation** (Logic App) routes high-severity alerts, kept **notify/approval-gated**, not auto-remediating.

The standard deployment model

> ***Assess*** *(map the MG hierarchy, current plan state, agents, workspaces, and cost inputs) →* ***Configure*** *(design the architecture + Bicep; enable and tune workload plans; set up export and the response workflow; build the lab objects) →* ***Pilot*** *(deploy plans on a pilot MG/subscription* `what-if` *first, run the labs, and run the benign PoC) →* ***Validate*** *(each phase has explicit pass/fail gates — inheritance, coverage, agents, export, alerts, knowledge-check, PoC scorecard) →* ***Expand*** *(roll out plans wave by wave across the hierarchy and to AWS/GCP; extend export, RBAC, and the response workflow). Every*

deployment is `what-if` ***/ plan first****, paid plans are* ***cost-gated****, and automated response stays* ***approval-gated****.*

Scope (what this solution produces)

• A **reference architecture** and decision record for MDC at scale, plus a deployable reference Bicep.

• **Workload protection plans** enabled and tuned on a pilot, with MDE integration, continuous export, a suppression rule, notifications, and a notify-first response workflow.

• A **management-group / multicloud rollout** in waves (AWS/GCP connectors) with RBAC and governance.

• **Team enablement** — five labs, a runbook, saved queries, and a knowledge-check.

• A **guided proof-of-concept** with benign signal, a scorecard, and a clean teardown.

• **Read-only** discovery, validation, and reporting scripts (PowerShell/Az + KQL), one preview-gated deploy/enable script, and the reference Bicep.

What is out of scope (and where it lives)

• **Day-to-day posture operations** — driving Secure Score, working the recommendation backlog, agentless scanning, attack-path remediation, and the CSPM cadence at scale — the **Defender for Cloud — CSPM & Secure Score Remediation** solution.

• **Full Azure landing-zone / cloud-adoption-framework design** — this designs the MDC layer, not the whole platform landing zone.

• **Deep per-cloud workload security in AWS/GCP** beyond connecting them for posture and enabling the available plans.

• **Building the SIEM/SOC on Sentinel** and cross-pillar hunting — the **Sentinel** and **Threat Hunting** solutions.

• **Regulatory-standard selection, remediation/exemption approval, cost acceptance, and incident-response decisions** — the customer's compliance / finance / security / operations functions.

Connections and authentication used

• The **Azure portal** → **Microsoft Defender for Cloud** (Environment settings, Defender plans, Governance, Continuous export, Security alerts, Recommendations, Regulatory compliance, Workflow automation) and **Management groups**.

• The **unified Defender portal** (`security.microsoft.com`) where workload alerts also surface and advanced hunting runs.

- **Az PowerShell** (`Az.Accounts`, `Az.Security`, `Az.Resources`, `Az.ResourceGraph`,

`Az.OperationalInsights`, `Az.Storage`) for read-only discovery, validation, reporting, the preview-gated deploy/enable, and PoC signal/teardown; **KQL / Azure Resource Graph** for hunting and the labs.

- **Bicep** (`main.bicep`) deployed via `az deployment mg what-if` / `New-AzManagementGroupDeployment -WhatIf` — **what-if first**.

- **AWS/GCP security connectors** for multicloud; a **Log Analytics workspace** and the **SIEM** as

export destinations.

- Least-privilege roles: **Security Reader** (read-only), **Security Admin** (manage plans/policies),

Owner/Contributor at scope (enable paid plans), **Management Group Contributor** (MG-scope deploy); **Global/Security Administrator** only for one-time tenant-level activations.

2. Requirements Guide — Microsoft Defender for Cloud

Verify **every** requirement before designing, enabling, training, or proving. Each entry: **Description · Why · Verify · Implement-if-missing.** The category-wide prerequisites (Microsoft 365 / Entra tenant, Defender licensing, admin roles, onboarding reach, network access, pilot ring, Log Analytics workspace, response governance) are in `global-requirements-defender.md` — read that first; the items below are **specific to this complete Defender for Cloud solution**. Objects are named `<Purpose> – <Scope> – <Stage>` and reused verbatim in every later step, script, and IaC parameter.

2.1 A management-group hierarchy and a pilot scope

Description: An Azure **management-group** hierarchy (at least a root and one intermediate node) with subscriptions under it — the target node for scaled enablement is `MDC Scope – Platform MG – Prod` — plus a **pilot** scope `MDC Scope – Pilot MG – Pilot` (a small MG or single subscription) to validate first. **Why:** Consistent, inheriting enablement is done at MG scope; the pilot limits blast radius and cost while the design is validated (per `global-requirements-defender.md` G6). **Verify:** `portal.azure.com` → `Management groups`; run `MDCFULL-Discovery.ps1` to map the hierarchy and where subscriptions sit. **Implement-if-missing:** Design a minimal hierarchy (root → platform/landing-zone → workload groups) and choose the pilot scope before enabling plans at scale.

2.2 A deployment identity with management-group rights

Description: An identity (user or service principal) with **Owner** or **Contributor + Security Admin** at the target MG scope, for the Bicep deployment and plan enablement; **Security Reader** for read-only work. **Why:** Enabling paid plans and deploying at MG scope requires write access at that scope; a service principal is preferred for pipeline deployment. **Verify:** Azure → **Access control (IAM)** at `MDC Scope – Platform MG – Prod`; `MDCFULL-Discovery.ps1` reports the running account's effective scope. **Implement-if-missing:** Grant the minimum role at the narrowest MG node; prefer PIM eligible activation or a scoped deployment service principal.

2.3 Resource providers registered

Description: The **Microsoft.Security** resource provider (and **Microsoft.PolicyInsights**) registered on the subscriptions in scope. **Why:** MDC assessments, plans, and the auto-provisioning policies require the providers registered. **Verify:** Azure → **Subscriptions** → **Resource providers** shows **Microsoft.Security** as Registered; `MDCFULL-Validate.ps1` checks this. **Implement-if-missing:** `Register-AzResourceProvider -ProviderNamespace Microsoft.Security` — the Bicep/MG policy can also drive this at scale.

2.4 Plan-enablement decision (which plans, which waves) and cost approval

Description: A decision on which plans to enable — foundational CSPM (free), **Defender CSPM** (paid), and which **workload plans** (Servers, Containers, Databases, Storage, Key Vault, App Service, Resource Manager) — in what rollout **waves**, with **business cost approval** and a named **budget owner** for the paid plans. **Why:** Every paid plan is billed per protected resource/node/transaction; the strategy sequences them so coverage and spend are deliberate, and someone must own the spend. **Verify:** `portal.azure.com → Microsoft Defender for Cloud → Environment settings → Defender plans`; `MDCFULL-Discovery.ps1` reports current plan tiers per subscription and `MDCFULL-Report.ps1 -Mode Cost` produces an indicative estimate from discovered resource counts. *Verify current plan pricing/availability in your tenant — the model is an estimate, not a quote.* **Implement-if-missing:** Draft the plan-per-wave matrix in the design record, collect the resource counts, and confirm the budget owner before enabling paid plans. **Whether a cost is acceptable is finance's decision.**

2.5 Agents/extensions provisioning for Servers

Description: The **Defender for Endpoint** integration and the required agent/extension (Azure Monitor Agent, and **Azure Arc** for non-Azure servers) auto-provisioned for Defender for Servers. **Why:** Server threat detection depends on the MDE sensor and monitoring agent being provisioned and healthy. **Verify:** **Environment settings** → **Defender plans** → **Servers** → **Settings** shows auto-provisioning; `MDCFULL-Validate.ps1 -Plan Servers` reports agent coverage. *Verify current agent/extension requirements.* **Implement-if-missing:** Enable auto-provisioning of the MDE integration and monitoring agent; connect non-Azure servers via **Azure Arc**.

2.6 Log Analytics workspace and SIEM target for continuous export

Description: A central Log Analytics workspace for **continuous export** and the **SIEM** it feeds: export named `MDC Continuous Export – Platform MG – Prod` (reuse the SIEM/observability workspace where appropriate — see `global-requirements-defender.md` G7). **Why:** Recommendations, Secure Score, and alerts land in a workspace and flow to the SIEM for trending, hunting, and correlation. **Verify:** `portal.azure.com → Log Analytics workspaces` and the SIEM connector; `MDCFULL-Discovery.ps1` reports workspaces. **Implement-if-missing:** Provision/select a central workspace and confirm the SIEM ingestion path before wiring continuous export.

2.7 Alert-tuning plan and a notify-first response workflow

Description: A plan for **alert tuning** (which known-benign alerts get the suppression rule `MDC Alert Suppression – Benign FP – Prod`, severities, and notification recipients) and a **workflow automation** (Logic App) `MDC Workload Response – Tenant – Prod` kept **notify/approval- gated** — not auto-remediating — during the pilot. **Why:** Untuned workload alerts create noise that buries real

detections; automated remediation on cloud workloads can disrupt production, so the organization decides the guardrails (per `global-requirements-defender.md` G8). **Verify:** `MDCFULL-Report.ps1 -Mode Alerts` lists current alerts/suppression; `MDCFULL-Validate.ps1 -Plan Workflow` reports the workflow is notify-only. **Implement-if-missing:** Draft the suppression rule, set email notifications, and create the workflow in notify-only mode. *Incident-response and auto-remediation decisions are the SOC/security team's.*

2.8 A pilot subscription with Secure Score populated (for enablement labs)

Description: A pilot subscription with MDC reachable, **Secure Score and recommendations populated**, and at least one Defender plan on (for the alerts lab). **Why:** The Phase C labs read live posture and alerts; assessments take time to populate after a subscription is onboarded. **Verify: Defender for Cloud** → **Overview / Secure Score / Environment settings** for the pilot; `MDCFULL-Validate.ps1` reports whether Secure Score data is present and a plan is on. **Implement-if-missing:** Nominate a non-production pilot subscription; allow an assessment warm-up window (*timing varies — verify in your tenant*); enable an inexpensive plan (e.g. Resource Manager or Storage) for the alerts lab.

2.9 Attendee/facilitator access and workstation tooling (for the labs)

Description: Attendees hold **Security Reader / Reader** on the pilot; the facilitator holds a change-capable role (**Security Admin / Owner**) for the `-WhatIf` rehearsal. The Az modules (`Az.Accounts`, `Az.Security`, `Az.ResourceGraph`) and **Azure Resource Graph / Advanced hunting** access are available. **Why:** Least privilege — attendees learn read-only; only the facilitator demonstrates a change, and only in `-WhatIf`. The lab helpers and KQL pack query posture/alert data. **Verify:** Azure → subscription → **Access control (IAM)**; `Get-Module -ListAvailable Az.Security, Az.ResourceGraph`; in **Resource Graph Explorer** run `securityresources | take 5`. **Implement-if-missing:** Assign the roles on the **pilot only**; `Install-Module Az -Scope CurrentUser`; grant Reader (ARG honors resource RBAC) and an advanced-hunting-read role for Defender XDR hunting.

2.10 Multicloud inputs (AWS/GCP, if in scope)

Description: The AWS accounts / GCP projects to connect and the roles/service accounts the connector requires — connectors `MDC Connector – AWS Prod – Prod`, `MDC Connector – GCP Prod – Prod`. **Why:** Multicloud posture needs a connector and a trust relationship into the target cloud; it is optional and scoped to a later wave. **Verify:** `portal.azure.com → Environment settings → Add environment (AWS/GCP)` requirements; `MDCFULL-Discovery.ps1` lists existing connectors. **Implement-if-missing:** Gather the AWS/GCP account inventory and required roles; connect only after the Azure pilot is validated. *Verify current connector requirements.*

2.11 A pilot resource group and evaluation criteria (for the PoC)

Description: A pilot resource group `MDC PoC – Pilot RG – Pilot` for the benign PoC test resource, and written **evaluation criteria** the scorecard is measured against. **Why:** The Phase D PoC runs on one subscription with a disposable, benign test resource; an objective verdict needs the criteria agreed up front. **Verify:** The RG exists (or one is chosen); a `criteria.json` of pass/fail bars exists. **Implement-if-missing:** Create the RG and draft the criteria (recommendation raised, Secure Score present, alert fired, compliance populated, latency acceptable) before Phase D.

2.12 Change control, pilot scope, and rollback

Description: An approved change record, the named pilot scope, and a documented rollback before enabling paid plans at MG scope. **Why:** MG-scope enablement affects many subscriptions and incurs cost; the what-if-first, pilot-first approach and a written back-out are the safety net. **Verify:** An approved change record, the pilot scope, and a written rollback (set plans back to Free / remove the MG assignment / delete the PoC test resource) exist. **Implement-if-missing:** Capture the baseline (`MDCFULL-Report.ps1 -Mode Coverage -SaveBaseline`), define the pilot scope, and write the rollback before any `-Apply`.

Checklist

- Management-group hierarchy mapped + pilot scope chosen — `MDCFULL-Discovery.ps1`
- Deployment identity with MG-scope rights (Owner / Contributor + Security Admin)
- Microsoft.Security provider registered — `MDCFULL-Validate.ps1`
- Plan-per-wave decision drafted + cost approval + budget owner — `MDCFULL-Report.ps1 -Mode Cost`
- Agents/extensions provisioning for Servers (MDE + monitoring agent + Arc)
- Central Log Analytics workspace + SIEM target (`MDC Continuous Export – Platform MG – Prod`)
- Alert-tuning plan + notify-only response workflow (`MDC Alert Suppression – Benign FP – Prod`, `MDC Workload Response – Tenant – Prod`)
- Pilot subscription with Secure Score populated + a plan on (labs)
- Attendee/facilitator access + Az modules + ARG access (labs)
- Multicloud (AWS/GCP) inputs gathered (if in scope)
- PoC pilot RG (`MDC PoC – Pilot RG – Pilot`) + written evaluation criteria
- Change window, pilot scope, and rollback documented

Global Requirements — Defender (category-level)

These requirements apply to every solution in the Defender category (Microsoft Defender XDR and Defender for Cloud). Published once at the category level so listings stay small. Confirm before deploying any Defender solution. Each entry: Description / Why / Verify / Implement-if-missing.

> *Defender changes touch detection and response for the whole tenant. Onboard in a ring (pilot devices/ users first), keep automated response in an approval/simulate posture until trusted, and never disable an existing control to "test."*

G1. Microsoft 365 / Entra tenant

Description: An active Microsoft 365 tenant with Entra ID. Why: Defender XDR services and the unified portal (security.microsoft.com) are tenant workloads. Verify: Sign in to

`https://security.microsoft.com` as an administrator. Implement: Provision a Microsoft 365 tenant and confirm Entra ID identities exist.

G2. Defender licensing

Description: The Defender plans for the pillars in scope — e.g. Defender for Endpoint P1/P2, Defender for Identity, Defender for Office 365 P1/P2, Defender for Cloud Apps, and Defender for Cloud plans. Why: Each pillar/feature is license-gated; onboarding without the plan fails or silently limits features. Verify: Admin center -> `Billing -> Licenses` (or the Defender portal). *Confirm the exact plan each feature needs — verify current availability in your tenant.* Implement: Assign the required plans (often bundled in M365 E5 / E5 Security) before onboarding.

G3. Administrative roles (least privilege)

Description: Security Administrator (and Global Administrator for first-time service activation). Why: Onboarding, RBAC, and policy changes in the Defender portal require these roles. Verify: Entra -> `Roles and administrators`; confirm Security Administrator. Implement: Assign Security Administrator; reserve Global Administrator for one-time activations.

G4. Onboarding reach to endpoints / identity / workloads

Description: A management channel to onboard the pillars — Intune/Configuration Manager/GPO/script for endpoints, domain controllers/AD FS for Identity sensors, and cloud connectors for Defender for Cloud. Why: Each pillar collects signal from a source that must be reachable and instrumented. Verify: Endpoints are managed (Intune/CM); DCs are reachable; cloud subscriptions are connected. Run the solution's discovery script. Implement: Establish the onboarding channel per pillar (see the relevant catalog endpoint/identity solutions).

G5. Network access to Defender service endpoints

Description: Outbound HTTPS to the Microsoft Defender / Microsoft 365 service URLs from onboarded assets. Why: Sensors and agents report to the cloud service; blocked endpoints break onboarding and detections. Verify: Confirm the documented Defender endpoint URLs/IP ranges are allowed. *Verify current endpoint list.* Implement: Allow the Defender/M365 endpoints through proxy/firewall.

G6. A pilot ring

Description: A defined set of pilot devices/users/subscriptions to onboard first. Why: XDR onboarding and automated response are validated on a ring before tenant-wide rollout. Verify: A pilot group exists in Entra/Intune. Implement: Create the pilot ring before enabling anything that acts automatically.

G7. Log Analytics workspace (where required)

Description: A Log Analytics workspace for Defender for Cloud / advanced hunting export where used. Why: Some Defender data and continuous export land in a workspace. Verify: A workspace exists and is access-controlled. Run the discovery script. Implement: Provision a workspace (or reuse the SIEM/observability one) with least-privilege access.

G8. Response governance

Description: An agreed position on automated response (auto-remediation levels, approval requirements). Why: XDR/AIR can take disruptive actions (isolate, delete, disable); the organization must decide the guardrails. Verify: A documented response policy exists; automation is in an approval/simulate posture until trusted. Implement: Define response guardrails; keep AIR/automation approval-gated at first. *Incident-response decisions are the SOC/security team's; this guide covers the technical configuration.*

The deployment model (all solutions): Assess -> Configure -> Pilot -> Validate -> Expand.

3. Implementation Guide — Microsoft Defender for Cloud

Follow the phases **in order**: **A) Architect** → **B) Protect (workload plans)** → **C) Enable the team** → **D) Prove value**, then **Expand**. Most work is in the **Azure portal** (`https://portal.azure.com` → `Microsoft Defender for Cloud`) with **Az PowerShell** helpers and the reference **Bicep**; alerts also surface in the unified Defender portal (`security.microsoft.com`). Objects are named `<Purpose> – <Scope> – <Stage>` and reused verbatim in every later step, script, and IaC parameter.

> ***Model:*** *Design the reference, validate it on the* ***pilot scope*** `MDC Scope – Pilot MG – Pilot` *with* `what-if`*, enable and tune the workload plans on the pilot subscription, train the team on the pilot, run a benign PoC, and only then expand wave by wave across the hierarchy and to AWS/GCP. Every deployment is* `what-if` ***/ plan first****, paid plans are* ***cost-gated****, and automated* ***response*** *stays notify/approval-gated. Never blind-apply infrastructure or auto-remediate a production workload to "test."* ***Posture remediation (Secure Score backlog) is the CSPM & Secure Score Remediation solution — cross-reference it, do not duplicate it here.***

Naming (set once, reuse verbatim)

- Platform (target) management group: `MDC Scope – Platform MG – Prod`
- Pilot management group / subscription: `MDC Scope – Pilot MG – Pilot`
- Pilot subscription for workload plans: `MDC Workload Plans – Pilot Subscription – Pilot`
- Design/decision record: `MDC Architecture Decision Record – Platform – Prod`
- Continuous export: `MDC Continuous Export – Platform MG – Prod`
- Governance rule: `MDC Governance – Platform MG – Prod`
- Multicloud connectors: `MDC Connector – AWS Prod – Prod`, `MDC Connector – GCP Prod – Prod`
- Alert suppression rule: `MDC Alert Suppression – Benign FP – Prod`
- Response workflow (Logic App): `MDC Workload Response – Tenant – Prod`
- Hunting saved query: `MDC Workload Alert Validation – Tenant – Validate`
- Lab artifacts: `SecureScore-Shortlist – Cloud Lab – Pilot`, `Recommendations – Cloud Lab – Pilot`, `Alerts-Triage – Cloud Lab – Pilot`, `SecureScore-Trend – Cloud Lab – Pilot`, `Compliance-Evidence – Cloud Lab – Pilot`

• PoC objects: `MDC PoC – Pilot RG – Pilot`, `MDC PoC Test Resource – Pilot RG – Pilot`, `MDC PoC Scorecard – Pilot Sub – Validate`, tag `MDC-PoC-TESTSIGNAL`

Phase A — Architect (design + reference Bicep)

Step A1 — Assess: map the estate, current state, and cost inputs

1. `portal.azure.com` → `Management groups`. Map the hierarchy and where subscriptions sit; identify the

target node `MDC Scope – Platform MG – Prod` and the pilot `MDC Scope – Pilot MG – Pilot`.

1. Run `MDCFULL-Discovery.ps1` to capture, read-only: the MG hierarchy, per-subscription Defender-for-

Cloud plan tiers, registered providers, Log Analytics workspaces, existing AWS/GCP connectors, agent coverage, and resource counts by type (the cost drivers).

1. Run `MDCFULL-Report.ps1 -Mode Coverage -SaveBaseline` to record the current coverage baseline, and

`MDCFULL-Report.ps1 -Mode Cost` for an indicative paid-plan estimate. *Verify current pricing.*

Step A2 — Design: produce the reference architecture and decision record

1. Write `MDC Architecture Decision Record – Platform – Prod` capturing:

• **Onboarding model** — which MG node plans are enabled at, and how inheritance covers current +

future subscriptions.

• **Plan-per-wave matrix** — foundational CSPM (all), Defender CSPM, and each workload plan (Servers,

Containers, Databases, Storage, Key Vault, App Service, Resource Manager) mapped to a rollout **wave**. *Verify current plan availability/pricing.*

• **RBAC model** — Security Reader (read posture) / Security Admin (manage plans+policies) / Owner or

Contributor at scope (enable paid plans) / Management Group Contributor (deploy) — least privilege by scope.

• **Multicloud** — which AWS accounts / GCP projects connect, and in which wave.

• **Continuous export / SIEM** — what is exported (recommendations, Secure Score, alerts) to which

workspace and onward to the SIEM.

• **Cost model** — the drivers and the indicative estimate, with the named budget owner.

1. Parameterize the included `main.bicep` to match the design (target MG, plans per wave, workspace,

export). This is the deployable form of the design — a **reference to adapt**, not a blind apply.

Step A3 — Pilot deploy: enable plans on the pilot scope (what-if first)

1. **Preview** the Bicep against the pilot scope — `MDCFULL-Deploy.ps1 -ManagementGroupId '<pilotMgId>'

-Wave 1 (defaults to -WhatIf, i.e. az deployment mg what-if`). Review exactly which plans would be set — expect **only** the intended wave-1 enablements at the pilot scope.

1. When the what-if is understood and approved, re-run with `-Apply` to enable the wave-1 plans on

the pilot scope only.

1. Confirm **Microsoft.Security** is registered on the pilot subscriptions (the deployment/policy can

drive this) — `MDCFULL-Validate.ps1`.

Step A4 — RBAC and governance on the pilot

1. Assign the **least-privilege roles** from the design at the pilot scope (Security Reader / Security

Admin / Owner-Contributor).

1. **Microsoft Defender for Cloud** → **Governance rules** → **Create** → `MDC Governance – Platform MG – Prod`

at the pilot scope: assign owners and due dates so recommendations are accountable. Structure the **exemption** policy (justified, time-bound). *Whether an exemption is acceptable is the security/compliance team's decision.*

Phase B — Protect (workload protection plans / CWPP)

Step B1 — Enable the workload plans on the pilot subscription

1. Choose the pilot subscription and record it as `MDC Workload Plans – Pilot Subscription – Pilot`

(a subscription under `MDC Scope – Pilot MG – Pilot`). Confirm **cost approval** for the pilot scope.

1. Azure portal → **Microsoft Defender for Cloud → Environment settings → [pilot subscription] →

Defender plans**. Turn** On **the plans in scope at the appropriate tier:** Servers **(P1 or P2),** Containers**,** Databases **(SQL / open-source / Cosmos DB),** Storage**,** Key Vault**,** App Service**,** Resource Manager**. *Verify current plan tiers and pricing.*

1. Preview and apply with the preview-gated helper: `MDCFULL-Deploy.ps1 -SubscriptionId '<pilot>' -Plans

Servers,Containers,StorageAccounts,SqlServers (safe -WhatIf preview by default; -Apply to enable per-subscription via Az.Security`).

1. Run `MDCFULL-Validate.ps1 -Plan All` to confirm the plans are **On** on the pilot subscription.

Step B2 — Wire Defender for Servers (MDE + agents)

1. **Environment settings** → **[pilot]** → **Defender plans** → **Servers** → **Settings** — confirm the **Defender for

Endpoint **integration and monitoring-agent auto-provisioning are** On**. Connect non-Azure servers via** Azure Arc**. *Verify current agent/extension requirements.*

1. Run `MDCFULL-Validate.ps1 -Plan Servers` to confirm agent/MDE coverage across the pilot servers.

Step B3 — Configure continuous export

1. **Environment settings** → **[pilot]** → **Continuous export** — export **Security alerts, recommendations,

and Secure Score** to `MDC Continuous Export – Platform MG – Prod` (and optionally the SIEM/Event Hub).

1. Confirm export is active and data begins landing in the workspace.
2. Run `MDCFULL-Validate.ps1 -Plan Export` to confirm continuous export is configured.

Step B4 — Tune alerts (suppression + notifications)

1. **Microsoft Defender for Cloud** → **Security alerts** — review the alerts appearing on the pilot; for

known-benign patterns create the suppression rule `MDC Alert Suppression – Benign FP – Prod` (scoped, documented — never over-broad).

1. **Environment settings** → **[pilot]** → **Email notifications** — set the recipients and the severity

threshold so the SOC gets high-severity alerts.

1. Run `MDCFULL-Report.ps1 -Mode Alerts` to capture the current alert inventory and suppression posture.

Step B5 — Add a notify-only response workflow

1. **Microsoft Defender for Cloud** → **Workflow automation** → **Add workflow automation** — create

`MDC Workload Response – Tenant – Prod` triggered on high-severity alerts, calling a Logic App that **notifies / creates a ticket** (Teams, email, ITSM). **No auto-remediation** during the pilot.

1. Run `MDCFULL-Validate.ps1 -Plan Workflow` to confirm the workflow exists and is notify-only.
2. *The decision to add any auto-remediation is the SOC/security team's — this guide leaves the workflow

notify/approval-gated.*

Phase C — Enable the team (labs, runbook, knowledge-check)

Run the labs in order against the **pilot subscription**. All steps are **read-only or preview-first /** `-WhatIf`; any plan-enable or Fix is **facilitator-driven,** `-WhatIf` **first, and approval-gated**. The KQL pack is `MDCFULL-LabPack.kql` (run ARG sections in **Resource Graph Explorer**, Defender-alert sections in **Advanced hunting**). *Microsoft moves portal blades periodically — verify current navigation in your tenant.*

Lab 0 — Readiness check (Assess)

1. Open **Microsoft Defender for Cloud** → **Overview** for the pilot subscription. Confirm Secure Score shows a value and at least one Defender plan is On.

1. Run `MDCFULL-Discovery.ps1 -SubscriptionId '<pilot sub id>'` and `MDCFULL-Validate.ps1 -SubscriptionId '<pilot sub id>'` — confirm plan tiers, Secure Score, provider registration, and connectors report, and readiness checks pass.

Lab 1 — Secure Score & recommendations

Goal: read the score, prioritize recommendations by impact, interpret a Fix.

1. **Defender for Cloud** → **Secure Score** — discuss what the weighted score represents and where the points are.

1. **Recommendations** — sort by **Potential score increase / impact**; walk 3–5 top items (what is wrong, which resources, the **Fix** action — *do not apply it yet*).

1. Discuss risk beyond raw score: an **attack-path**-linked or internet-exposed finding outranks an isolated low-severity one.

1. In **Resource Graph Explorer**, run the **Recommendations** section of `MDCFULL-LabPack.kql`; **Save as `Recommendations – Cloud Lab – Pilot`**.

1. Start the `SecureScore-Shortlist – Cloud Lab – Pilot` — top recommendations by impact/effort.

Remediation and change approval belong to the customer's cloud-ops/security functions — this is the CSPM & Secure Score Remediation solution's program.

Lab 2 — Workload-protection alerts

Goal: understand the Defender plans and triage a security alert.

1. **Environment settings** → **[pilot]** → **Defender plans** — review which CWPP plans exist and what each protects. *Several are paid — verify pricing/availability.*

1. **Security alerts** — if empty, use the portal **sample alerts** action (pilot only) to generate benign alerts.

1. Triage one alert: severity, affected resource, the **MITRE** tactic/technique, the activity, and the first response step.

1. In Advanced hunting / ARG, run the **Alerts triage** section of `MDCFULL-LabPack.kql`; **Save as `Alerts-Triage – Cloud Lab – Pilot`**.

1. Discuss the hand-off: MDC alerts flow to Defender XDR / Sentinel; the SOC owns the incident decision.

Lab 3 — Regulatory compliance

Goal: read the compliance dashboard and export evidence — read-only.

1. **Defender for Cloud** → **Regulatory compliance** — review the standards assigned and pass/fail controls.

1. Pick one standard; drill into a failing control to see mapped recommendations and affected resources.

2. Export the compliance report/evidence (PDF/CSV where offered) as `Compliance-Evidence – Cloud Lab – Pilot` — read-only.

1. **Boundary:** *which* standards apply and whether a gap/exemption is acceptable are the **compliance team's** determination — the labs show how to read and evidence, not what to certify.

Lab 4 — Multicloud connectors

Goal: understand how AWS/GCP connectors extend posture.

1. **Environment settings** — if an AWS/GCP connector exists, open it; review the account, enabled plans, and its recommendations in the unified list.

1. If none exists, walk the **concept**: a connector uses a cross-cloud role/identity to read the other cloud's config, mapping its findings into the same Secure Score/recommendation model.

1. Discuss scope honestly: multicloud here is **high-level posture**; deep per-cloud workload protection is a larger, separate effort.

Lab 5 — Remediation cadence & reporting (preview-first)

Goal: build a prioritized shortlist, rehearse an enable/Fix in `-WhatIf`, produce a trend report.

1. Finalize `SecureScore-Shortlist – Cloud Lab – Pilot`: top 3–5 items with owner candidates and effort.

2. **Rehearse a change in preview (facilitator):** run `MDCFULL-Deploy.ps1 -SubscriptionId '<pilot sub id>' -Plans StorageAccounts with -WhatIf` (default) to see what enabling a plan *would* do — it makes **no** change. Discuss the real enable path and the rollback.

1. Run `MDCFULL-Report.ps1 -SubscriptionId '<pilot sub id>' -Mode Coverage` to produce a Secure-Score +

recommendations report. Save the ARG trend query as `SecureScore-Trend – Cloud Lab – Pilot`.

1. Capture the operating cadence: how often to review score, who owns recommendations, and how drift is

caught (continuous export / the trend query).

1. **Boundary:** the labs **do not enforce** posture changes. Enabling plans and applying Fixes at scale

follow the customer's change process and the **CSPM & Secure Score Remediation** solution.

Wrap-up

1. Confirm the take-home artifacts: the three saved queries, the shortlist, the compliance export, and

the ops-notes.

1. Run the **knowledge-check** in `05-testing.md` (Part B).

Phase D — Prove value (guided, benign proof-of-concept)

Run the PoC on **one pilot subscription** with the pilot RG `MDC PoC – Pilot RG – Pilot`. All signal is **benign** (sample alerts + a benign misconfigured test resource + EICAR). Every change is `-WhatIf`-**gated**; teardown **disables the paid plan to stop billing**. No other subscription is touched.

Step D1 — Assess readiness (read-only)

1. `Connect-AzAccount` and select the pilot subscription.

2. Run `MDCFULL-PoC.ps1 -Action Assess` (a `-WhatIf` preview) — previews Azure roles, the pilot

subscription, current plan state, and candidate resources.

1. Create/confirm the pilot RG `MDC PoC – Pilot RG – Pilot`. **Confirm the cost owner accepts the short

Defender-plan billing window.**

Step D2 — Enable CSPM + one workload plan on the pilot subscription

1. **Environment settings** → **(pilot subscription)** → **Defender plans** — turn on **CSPM** (foundational

free; Defender CSPM paid — *verify pricing/availability*) and **one** workload plan (e.g. Defender for Servers or Storage) for the pilot subscription only.

1. Or run `MDCFULL-Deploy.ps1 -SubscriptionId '<pilot>' -Plans StorageAccounts -Apply` (preview-gated).

2. Confirm the plans show **On** for the pilot subscription.

Step D3 — Generate benign test signal

1. Run `MDCFULL-PoC.ps1 -Action TestSignal -ResourceGroup 'MDC PoC – Pilot RG – Pilot' -DeployTestResource`

(`-WhatIf` previews). It performs only **benign, documented** actions tagged `MDC-PoC-TESTSIGNAL`:

• **Sample security alerts** — **Security alerts** → **Sample alerts** → select the pilot subscription →

Create (Microsoft-provided, benign).

• **Benign misconfiguration (CSPM)** — deploy `MDC PoC Test Resource – Pilot RG – Pilot` (e.g. a

storage account with public blob access) so a **recommendation** is raised. It holds **no real data**.

• **Workload threat (optional)** — on a pilot VM covered by Defender for Servers, drop the **EICAR**

test file for a benign Defender-for-Servers alert.

1. **Never** attack real resources, deploy real malware, or expose real data. Note each signal's time

for the scorecard latency comparison.

Step D4 — Validate and demonstrate the detections

1. Run `MDCFULL-Validate.ps1 -PoC` — confirms (read-only) the **recommendation**, **Secure Score**,

security alerts (sample + EICAR), and **regulatory-compliance** data.

1. In the portal, walk the demo: **Recommendations → Secure Score → Security alerts → Regulatory

compliance** — the headline-capability demo for stakeholders.

1. Confirm nothing outside the pilot subscription was affected.

Step D5 — Score against your criteria

1. Run `MDCFULL-PoC.ps1 -Action Scorecard -CriteriaPath .\criteria.json -OutFile 'MDC PoC Scorecard –

Pilot Sub – Validate.json'` — maps each observation to your pass/fail criteria.

1. Review the scorecard with stakeholders — the decision artifact.

Step D6 — Tear down (clean rollback + stop billing)

1. Run `MDCFULL-PoC.ps1 -Action Teardown -WhatIf` first to preview, then without `-WhatIf`.

2. Teardown **deletes** the test resource `MDC PoC Test Resource – Pilot RG – Pilot`, **disables** the

Defender workload plan (sets it back to Free) on the pilot subscription **to stop billing**, and **resolves/dismisses** the `MDC-PoC-TESTSIGNAL` sample alerts.

1. Keep the scorecard as your record. Re-run `MDCFULL-Validate.ps1 -PoC` to confirm the plan is Off and

the test resource is gone.

Expand (across the hierarchy and multicloud)

1. **Plans (IaC):** re-target `main.bicep` at `MDC Scope – Platform MG – Prod` and deploy **wave by

wave** — always `MDCFULL-Deploy.ps1` (`-WhatIf`) first, then `-Apply` — so new and existing subscriptions inherit each wave's plans, watching cost.

1. **Agents/export:** confirm agent provisioning and continuous export on each new subscription.

2. **Alerts/workflow:** extend the suppression rule and `MDC Workload Response – Tenant – Prod` tenant-

wide; only after validation consider approval-gated auto-remediation with the SOC.

1. **RBAC/governance:** roll the RBAC model and `MDC Governance – Platform MG – Prod` out to the expanded

scope.

1. **Multicloud:** add `MDC Connector – AWS Prod – Prod` / `MDC Connector – GCP Prod – Prod` in their

designed wave, after the Azure pilot is validated. *Verify current connector requirements.*

1. **Team & posture:** apply the enablement runbook to onboard new engineers, and hand the Secure-Score

remediation cadence to the **CSPM & Secure Score Remediation** solution.

1. Re-baseline with `MDCFULL-Report.ps1 -Mode Coverage -SaveBaseline` after each wave and track

coverage/cost drift. Update the decision record as the architecture evolves.

Order of operations

`Architect (assess estate + cost → design record + Bicep → pilot deploy plans what-if→apply → RBAC + governance) → Protect (enable workload plans on pilot sub → Servers MDE/agents → continuous export → tune alerts → notify-only response workflow) → Enable the team (Labs 0–5 + knowledge-check) → Prove value (benign PoC: enable → signal → validate/demo → score → teardown that disables paid plans) → Expand waves across the MG hierarchy (+ AWS/GCP)`

5. Testing Guide — Microsoft Defender for Cloud

Validate each phase against its **pass/fail gate** before moving on. Do not expand across the hierarchy until the pilot passes every gate. Objects are referenced by the exact names from the Implementation Guide. Keep every deployment **what-if first** and all PoC signal **benign**.

Part A — Architect (Phase A)

A1 — Design record and Bicep parameterized

Procedure: Confirm `MDC Architecture Decision Record – Platform – Prod` exists with the onboarding model, plan-per-wave matrix, RBAC model, multicloud plan, export design, and cost model; and that `main.bicep` parameters match it. **Pass:** The design record is complete and the Bicep reflects it. **Fail:** Missing sections or Bicep drift — complete Implementation Step A2.

A2 — Bicep what-if is clean before apply

Procedure: Run `MDCFULL-Deploy.ps1 -ManagementGroupId '<pilotMgId>' -Wave 1` (default `-WhatIf`). **Pass:** The what-if shows **only** the intended plan enablements at the pilot scope — no unexpected changes. **Fail:** Unexpected/out-of-scope changes — fix the Bicep/parameters; do **not** `-Apply`. See Troubleshooting *What-if shows unexpected changes*.

A3 — Plans enabled + inheritance working at the pilot scope

Procedure: Run `MDCFULL-Validate.ps1`. Confirm wave-1 plans are **On** at `MDC Scope – Pilot MG – Pilot`, and pick a subscription **under** the pilot MG to confirm it shows the **inherited** plan. **Pass:** Designed plans enabled at MG scope and a child subscription inherits. **Fail:** Off/Free or no inheritance — see Troubleshooting *Plan not enabling at MG scope* / *Inheritance not applying*.

A4 — Providers registered + RBAC/governance in place

Procedure: Run `MDCFULL-Validate.ps1`. Confirm **Microsoft.Security** is Registered, the designed least-privilege roles are assigned at the pilot scope, and `MDC Governance – Platform MG – Prod` exists with owners/due dates and time-bound exemptions. **Pass:** Provider registered; RBAC matches the design; governance rule present. **Fail:** Over-broad role or missing governance/provider — see Troubleshooting *RBAC sprawl / missing governance* / *Provider not registered*.

Part B — Protect (Phase B)

B1 — Workload plans enabled on the pilot subscription

Procedure: Run `MDCFULL-Validate.ps1 -Plan All`; confirm the in-scope plans (Servers/Containers/ Databases/Storage/Key Vault/App Service/Resource Manager) are **On** for `MDC Workload Plans – Pilot Subscription – Pilot`. **Pass:** Every in-scope plan On at the agreed tier. **Fail:** A plan Off/wrong tier — re-apply Implementation Step B1.

B2 — Defender for Servers coverage (MDE + agent)

Procedure: Run `MDCFULL-Validate.ps1 -Plan Servers`; confirm MDE and the monitoring agent are provisioned and healthy on the pilot servers (Arc for non-Azure). **Pass:** Pilot servers report MDE/agent healthy; server detection active. **Fail:** Not provisioned — see Troubleshooting *Server agent not provisioned*.

B3 — Continuous export flowing

Procedure: Run `MDCFULL-Validate.ps1 -Plan Export`; confirm alerts/recommendations/Secure Score land in `MDC Continuous Export – Platform MG – Prod` (the `SecurityAlert` table) and reach the SIEM. **Pass:** Export active and data landing; SIEM path present. **Fail:** No data — see Troubleshooting *Continuous export no data*.

B4 — Alert tuning in place

Procedure: Run `MDCFULL-Report.ps1 -Mode Alerts`; confirm `MDC Alert Suppression – Benign FP – Prod` exists (scoped/documented) and email notifications are set with a sensible severity threshold. **Pass:** Suppression rule + notifications configured; the queue is signal, not noise. **Fail:** No tuning or over-broad suppression — re-apply Implementation Step B4.

B5 — Response workflow is notify-only

Procedure: Run `MDCFULL-Validate.ps1 -Plan Workflow`; confirm `MDC Workload Response – Tenant – Prod` triggers on high-severity alerts and **only notifies / creates a ticket**. **Pass:** The workflow notifies and does not remediate during the pilot. **Fail:** Auto-remediation configured before agreed — reset to notify-only and confirm with the SOC.

B6 — Coverage rose and cost matches the model

Procedure: Run `MDCFULL-Report.ps1 -Mode Coverage -BaselinePath .\mdcfull-baseline.json` and `-Mode Cost`. **Pass:** Coverage on the pilot is **higher** than baseline and drivers are within the cost model's estimate. **Fail:** Unchanged or cost far exceeds estimate — reconcile before expanding; *verify current pricing.* See Troubleshooting *Cost exceeds the model*.

Part C — Enable the team (Phase C)

C1 — Environment / lab validation (scripts)

Run `MDCFULL-Validate.ps1 -SubscriptionId '<pilot sub id>'` (Az connectivity, `Microsoft.Security` registered, Secure Score present, a plan on, ARG access) and `MDCFULL-Discovery.ps1 -SubscriptionId '<pilot sub id>'`. Confirm the saved queries `Recommendations – Cloud Lab – Pilot`, `Alerts-Triage – Cloud Lab – Pilot`, and `SecureScore-Trend – Cloud Lab – Pilot` exist and run without error, and that the `-WhatIf` rehearsal (`MDCFULL-Deploy.ps1 -SubscriptionId '<pilot>' -Plans StorageAccounts`) made **no** change. **Pass:** All green; queries run; the rehearsal changed nothing. **Fail:** Resolve via Requirements 2.8–2.9.

C2 — Knowledge-check (per attendee; pass = ≥8/10)

1. **CSPM vs CWPP:** the difference, and which surface each maps to (Secure Score/Recommendations vs

Security alerts)?

1. **Secure Score:** what it represents, and how to find the highest-impact recommendations?
2. **Foundational vs Defender CSPM:** what the free tier gives vs what paid Defender CSPM adds

(agentless scanning, attack paths, risk hunting)?

1. **Attack paths:** why an attack-path-linked finding can outrank a higher-raw-severity isolated one?
2. **Defender plans:** name three CWPP plans and what each protects.
3. **Alert triage:** the four things you read first (severity, resource, MITRE, activity)?
4. **Compliance:** how to drill from a standard to the resources causing a failing control, and who

chooses the standard?

1. **Connectors:** what an AWS/GCP connector does, and the limit of multicloud coverage here?
2. **Reporting/drift:** how to catch posture drift over time (continuous export / trend query / cadence)?
3. **Boundary & governance:** which decisions (standard selection, remediation approval, exemption acceptance) belong to the customer's functions?

C3 — Live demonstration (capstone)

Each attendee, unaided, on the pilot: opens Secure Score and states the top item's impact; triages one alert (severity, resource, MITRE, first step); runs one saved query and interprets a result. **Pass:** Every attendee meets C2 (≥8/10) and completes C3. Anyone below threshold repeats the relevant lab.

Part D — Prove value (Phase D PoC)

D1 — Plan enabled on the pilot subscription only

Procedure: Run `MDCFULL-PoC.ps1 -Action Assess`; confirm CSPM + the chosen workload plan show **On** for the pilot subscription and **no other**. **Pass/Fail:** On for the pilot only / see Troubleshooting *Plan not enabling*.

D2 — Benign signal generated

Procedure: Run `MDCFULL-PoC.ps1 -Action TestSignal`; confirm sample alerts created, the benign test resource deployed, and (optionally) EICAR dropped. **Pass:** All benign signals generated, no real attack/malware. **Fail:** see Troubleshooting *Signal not generated*.

D3 — Recommendation, Secure Score, alert, and compliance populated

Procedure: Run `MDCFULL-Validate.ps1 -PoC`. Confirm a **recommendation** for the benign misconfig, a **Secure Score**, the **security alerts** (sample + EICAR), and **regulatory-compliance** data. **Pass:** All four observed (allow warm-up). **Fail:** see Troubleshooting *No recommendation / No Secure Score / No security alert / No compliance data*.

D4 — Scorecard produced

Procedure: Run `MDCFULL-PoC.ps1 -Action Scorecard`; confirm `MDC PoC Scorecard – Pilot Sub – Validate.json` maps every observation to a pass/fail criterion. **Pass:** Complete scorecard. **Fail:** re-run the relevant validate step first.

D5 — Clean teardown (and billing stopped)

Procedure: Run `MDCFULL-PoC.ps1 -Action Teardown -WhatIf`, then without; re-run `MDCFULL-Validate.ps1 -PoC`. **Pass:** The test resource is deleted, the Defender plan is **Off** (billing stopped), and sample alerts resolved. **Fail:** Residue or plan still on — see Troubleshooting *Teardown left residue*.

Exit gates

- **Phase A/B:** A1–A4 and B1–B6 pass on the pilot **before** any hierarchy-wide or multicloud expansion. Re-run A2–A4 and B1, B3, B6 after each wave and compare against the re-saved baseline.
- **Phase C:** Every attendee meets C2/C3 and C1 is green.

• **Phase D:** D1–D4 pass to call the PoC conclusive; D5 passes to close it out cleanly **and stop billing**. Keep the scorecard as the decision record.

6. Troubleshooting Guide — Microsoft Defender for Cloud

Common field issues across all four phases, in **symptom** → **cause** → **fix** form. Run `MDCFULL-Discovery.ps1` and `MDCFULL-Validate.ps1` first — most causes surface there.

Phase A — Architect

What-if shows unexpected changes

Symptom: `MDCFULL-Deploy.ps1 -WhatIf` predicts changes beyond the intended plan enablements (or on the wrong scope). **Cause:** The Bicep parameters target the wrong management group, include plans not in the current wave, or drift from the design record. **Fix:** Re-parameterize `main.bicep` to the pilot scope and wave-1 plans only; reconcile against `MDC Architecture Decision Record – Platform – Prod`; re-run the what-if until it shows **only** the intended changes. Do **not** `-Apply` until it is clean.

Plan not enabling at MG scope

Symptom: After `-Apply`, plans still show Off/Free at `MDC Scope – Pilot MG – Pilot`. **Cause:** The deployment identity lacks **Owner / Contributor + Security Admin** at the MG scope, the **Microsoft.Security** provider isn't registered, or the plan isn't available in the region/tenant. **Fix:** Confirm the identity's role at the MG node (Requirement 2.2); register the provider; *verify the plan's availability/pricing in your tenant.* Re-run `MDCFULL-Deploy.ps1 -Apply` and `MDCFULL-Validate.ps1`.

Inheritance not applying

Symptom: A subscription under the pilot MG shows Free / no inherited plan. **Cause:** The plan was set at **subscription** scope (or a lower MG) instead of the intended MG node, the subscription overrides inheritance with its own setting, or the provider isn't registered on it. **Fix:** Confirm the plan is set at the **management-group** scope; remove any conflicting per-subscription override; register **Microsoft.Security** on the subscription. Re-check with `MDCFULL-Validate.ps1`.

Provider not registered

Symptom: `MDCFULL-Validate.ps1` reports **Microsoft.Security** not registered on a subscription. **Cause:** Never registered, or a new subscription joined without it. **Fix:** `Register-AzResourceProvider -ProviderNamespace Microsoft.Security`, or let the MG-scope Azure Policy auto-register it. Allow a few minutes and re-validate.

RBAC sprawl / missing governance

Symptom: Over-broad roles (e.g. Owner where Security Reader suffices) or no governance rule at scope. **Cause:** Roles granted ad-hoc during rollout, or Step A4 skipped. **Fix:** Re-align role assignments to the least-privilege model; grant at the narrowest MG node; create `MDC Governance – Platform MG – Prod` with owners/due dates and time-bound exemptions. Re-run `MDCFULL-Validate.ps1`. *Exemption acceptability is the security/compliance team's decision.*

Cost exceeds the model

Symptom: Actual MDC spend is well above `MDCFULL-Report.ps1 -Mode Cost`'s estimate. **Cause:** A plan was enabled at a higher MG node than intended (billing more descendant resources), resource counts grew, or a costly workload plan landed in an early wave. **Fix:** Check where each plan is enabled in the MG hierarchy; move expensive plans to later waves or a narrower scope; re-run the cost report with current counts; confirm with the budget owner. *Whether the cost is acceptable is finance's decision.* Rollback: set the plan back to Free or remove the MG-scope assignment.

Phase B — Protect

Plan will not enable (subscription scope)

Symptom: B1 fails — a workload plan stays **Off** or the enablement errors. **Cause:** The account lacks **Security Admin / Owner** on the subscription, `Microsoft.Security` is not registered, or a policy blocks the change. **Fix:** Confirm the role (IAM); register the provider; check for a blocking Azure Policy. Re-run `MDCFULL-Deploy.ps1 -SubscriptionId <pilot> -Plans … -Apply` and `MDCFULL-Validate.ps1 -Plan All`.

Server agent not provisioned

Symptom: B2 fails — pilot servers show no MDE/monitoring agent, or detection is inactive. **Cause:** Auto-provisioning is off, the monitoring agent/extension failed to deploy, or a non-Azure server is not Arc-connected. **Fix:** In **Defender plans** → **Servers** → **Settings**, enable auto-provisioning of the MDE integration and monitoring agent; connect non-Azure servers via **Azure Arc**; check the extension deployment status on the VM. *Verify current agent/extension requirements.* Re-run `MDCFULL-Validate.ps1 -Plan Servers`.

Continuous export no data

Symptom: B3 fails — no alerts/recommendations/Secure Score land in `MDC Continuous Export – Platform MG – Prod`, or the SIEM receives nothing. **Cause:** Export is not configured, points at the wrong workspace, exports the wrong data types, no alerts have fired yet, or the SIEM connector isn't wired. **Fix:** Confirm **Environment settings** → **Continuous export** targets the workspace and exports Security alerts + recommendations + Secure Score; confirm workspace permissions and the SIEM ingestion path; allow warm-up and generate a benign alert (Phase D). Re-run `MDCFULL-Validate.ps1 -Plan Export`.

Alert noise / too many alerts

Symptom: The pilot alert queue is overwhelming. **Cause:** No alert tuning yet, or a benign workload behavior repeatedly triggers a detection. **Fix:** Create **scoped, documented** suppression rules (`MDC Alert Suppression – Benign FP – Prod`) only for genuinely benign patterns, set the notification severity threshold, and fix the underlying misconfiguration where possible (CSPM). Re-run `MDCFULL-Report.ps1 -Mode Alerts`.

Response workflow auto-remediated

Symptom: A workload was changed automatically during the pilot. **Cause:** `MDC Workload Response – Tenant – Prod` was configured to remediate rather than notify. **Fix:** Reset the workflow/Logic App to **notify / ticket-only** (Step B5), confirm with the SOC, and re-validate (`MDCFULL-Validate.ps1 -Plan`

Workflow). *The auto-remediation decision is the security team's.*

Phase C — Enable the team

No workload alerts to triage

Symptom: Lab 2 has an empty Security alerts queue. **Cause:** Plans newly enabled and warming up, or no threats/tests have occurred. **Fix:** Confirm at least one plan is On; use the portal **sample alerts** action (pilot only) to generate benign alerts; allow warm-up. Re-run `MDCFULL-Discovery.ps1`.

Saved query returns nothing / ARG access denied

Symptom: A `MDCFULL-LabPack.kql` section returns no rows or errors on access. **Cause:** The attendee lacks **Reader** (ARG honors resource RBAC), Secure Score hasn't populated, or an ARG `securityresources` type/column shifted. **Fix:** Grant Reader on the pilot; allow assessment warm-up; *verify current ARG schema in your tenant*; for Defender-alert sections use **Advanced hunting** with an advanced-hunting-read role.

Preview rehearsal appears to change something

Symptom: The Lab 5 `-WhatIf` rehearsal looks like it enabled a plan. **Cause:** It was run **without** `-WhatIf` (the default is preview, but a `-Apply` slipped in). **Fix:** The rehearsal must be `MDCFULL-Deploy.ps1 …` **without** `-Apply` — it changes nothing. If a plan was enabled, disable it (`MDCFULL-PoC.ps1 -Action Teardown` or set to Free in the portal).

Phase D — Prove value (PoC)

Plan not enabling

Symptom: CSPM or the workload plan does not turn **On** for the pilot subscription. **Cause:** Insufficient role (needs Security Admin/Contributor/Owner), wrong subscription selected, or a policy blocks the change. **Fix:** Confirm your role (**Access control (IAM)**); `Set-AzContext` to the correct subscription; re-run `MDCFULL-PoC.ps1 -Action Assess` and check the reported gaps.

Signal not generated

Symptom: Sample alerts, the test resource, or EICAR did not generate. **Cause:** The sample-alert action targeted the wrong subscription, the test-resource deployment failed (naming/quota), or the pilot VM is not covered by Defender for Servers. **Fix:** Create sample alerts against the pilot subscription; confirm the test resource deployed in `MDC PoC – Pilot RG – Pilot`; confirm the VM is covered before using EICAR. Re-run `MDCFULL-PoC.ps1 -Action TestSignal`.

No recommendation / No Secure Score / No security alert / No compliance data

Symptom: D3 fails — one or more of the four observations is missing. **Cause:** Assessment/alert pipeline is still warming up, the resource isn't misconfigured in an assessed way, the workload plan is off, the account lacks read permission, or the default benchmark isn't applied. **Fix:** Allow warm-up (minutes to hours); confirm the test resource has the intended misconfiguration (e.g. public blob access); confirm the workload plan is **On** and **Security Reader** is held; confirm the Microsoft Cloud Security Benchmark is applied. *Some standards are plan-gated — verify availability.* Re-run `MDCFULL-Validate.ps1 -PoC`.

Teardown left residue

Symptom: After teardown, the test resource remains or the plan is still **On** (still billing). **Cause:** Teardown ran in `-WhatIf` only, or a delete/disable failed on a permission. **Fix:** Run `MDCFULL-PoC.ps1 -Action Teardown` **without** `-WhatIf`; confirm the plan shows **Off** in **Environment settings** → **Defender plans** (this stops billing); delete `MDC PoC Test Resource – Pilot RG – Pilot`; resolve the `MDC-PoC-TESTSIGNAL` alerts; re-confirm with `MDCFULL-Validate.ps1 -PoC`.

All phases — script/auth

Script or deployment cannot authenticate

Symptom: `MDCFULL-*.ps1` fails on connect/returns access-denied, or the MG deployment errors on auth/scope. **Cause:** The Az modules (`Az.Accounts`, `Az.Security`, `Az.Resources`, `Az.ResourceGraph`, `Az.OperationalInsights`, `Az.Storage`) are missing, the account isn't signed in to the right subscription/tenant, or it lacks the required role/MG-scope rights. **Fix:** Let the script install the modules (it checks on run); `Connect-AzAccount` and `Set-AzContext` to the right subscription; confirm **Security Reader** (read) / **Security Admin + Contributor** or MG-scope Owner (change); for pipeline runs use a scoped deployment service principal. Re-run.

7. Best Practices — Microsoft Defender for Cloud

Field-proven guidance for keeping the whole Defender for Cloud lifecycle designed, protective, tuned, and cost-aware.

Design before you deploy — and keep the decision record

- Write `MDC Architecture Decision Record – Platform – Prod` first (onboarding model, plan-per-wave

matrix, RBAC, multicloud, export, cost model). A rollout without a design record is how RBAC sprawl and cost surprises happen. Keep it current as the architecture evolves — it is the map the next engineer and the next audit rely on.

Enable at management-group scope, not subscription by subscription

- The whole point is **inheritance**: enable plans at `MDC Scope – Platform MG – Prod` so every current

and future subscription is protected automatically. Per-subscription enablement is exactly the drift this solution exists to prevent. Use the MG hierarchy and rollout **waves** to control blast radius — a plan enabled at a high node protects *and bills* every descendant.

Deploy what-if first, always; treat the Bicep as a reference to adapt

- Every Bicep deployment runs `MDCFULL-Deploy.ps1 -WhatIf` (`az deployment mg what-if`) first; review the

predicted changes; only then `-Apply`. Never blind-apply infrastructure that enables paid plans across an estate. Source-control and peer-review `main.bicep`; verify the built-in initiative/definition ids in your tenant — they are versioned.

Treat cost as a first-class decision, and name a budget owner

• Workload plans and Defender CSPM are **billed per resource/node/transaction**. Get cost approval for

the pilot, track drivers with `MDCFULL-Report.ps1 -Mode Cost`, sequence expensive plans into later waves, and get a **named finance owner** to accept the spend. **Whether a cost is acceptable is finance's decision** — the model informs it. *Verify current plan pricing and availability in your tenant — the model is an estimate, not a quote.*

Pair CWPP with CSPM, don't substitute — cross-reference the posture solution

• Workload protection **detects** attacks; CSPM **reduces** the attack surface. Keep both. Driving Secure

Score, working the recommendation backlog, agentless scanning, and attack-path remediation at scale is the catalog's **Defender for Cloud — CSPM & Secure Score Remediation** solution — hand posture operations to it rather than duplicating that program here. Fixing posture lowers the alerts CWPP has to raise.

Provision the Servers agents properly

• Defender for Servers detection is only as good as its **agents**. Confirm the MDE integration and

monitoring agent auto-provision and stay healthy, and connect non-Azure servers via **Azure Arc** so multicloud/on-prem workloads are covered.

Tune alerts so the SOC trusts them; keep response notify-first

• Untuned CWPP alerts become noise. Create **scoped, documented** suppression rules (`MDC Alert

Suppression – Benign FP – Prod`) only for genuinely benign patterns, set sensible severities, and route high-severity alerts to the SOC. Start MDC Workload Response – Tenant – Prod` as **notify / ticket- only** — auto-remediation of a production workload is disruptive and belongs to the SOC's decision, made only after the alerts are trusted.

Export once, centrally, to the SIEM

• Stream recommendations, Secure Score, and alerts to a **central** workspace and onward to the SIEM

(`MDC Continuous Export – Platform MG – Prod`). One central export beats per-subscription exports for trending, hunting, and correlation — and it is what feeds the labs' trend query and the SOC.

Make governance and exemptions explicit

• Use `MDC Governance – Platform MG – Prod` to assign owners and due dates so recommendations are

accountable at scale. Every exemption is **justified and time-bound** — never a silent, permanent suppression. *Whether an exemption is acceptable is the security/compliance team's decision.*

Train against the pilot, preview-first; and prove value benignly

• Teach the team on the pilot with everything read-only or `-WhatIf`; only the facilitator demonstrates a

change, and only in preview. Prove value with the **benign PoC** (sample alerts + a benign misconfig test resource + EICAR) — never a real attack, real malware, or exposed data — and **disable the paid plan at teardown** to stop billing. Diarise the teardown so a plan is never left on by accident.

Add multicloud after the Azure pilot is solid

• Connect AWS/GCP (`MDC Connector – AWS Prod – Prod` / `– GCP Prod – Prod`) in their designed wave, once

the Azure onboarding model, RBAC, and export are proven. Multicloud connectors give posture and the available plans — not a substitute for each cloud's deep native controls.

Defer the decisions to the owners

• Which regulatory standards apply, whether a gap/exemption/cost is acceptable, remediation and

incident-response approval, and production change control are **the customer's** compliance / finance / security / operations determinations. This solution delivers the technical build — the architecture, the workload protection, the trained team, and the proof — not the decision.

Where to go next

Once MDC is architected, protecting workloads, team-run, and proven, natural next steps in the catalog:

• **Microsoft Defender for Cloud — CSPM & Secure Score Remediation** — the posture *program*: drive

Secure Score, work the recommendation backlog, agentless scanning, and the remediation cadence at scale on the platform this solution stands up.

• **Microsoft Defender XDR — Unified Onboarding** to correlate cloud workload alerts with Endpoint,

Identity, Office, and Cloud Apps.

• The **Microsoft Defender for Endpoint** — MDE powers Defender for Servers

detection.

• The **SOC onboarding — Sentinel + Defender XDR** and **advanced KQL threat-hunting** solutions to turn

the continuous-export/SIEM feed into hunting and SOAR.

• **Azure Security Baseline & Governance** to enforce secure configuration with Azure Policy guardrails

alongside Defender for Cloud.

8. Deliverables Summary — Microsoft Defender for Cloud

Documentation (source/)

1. **executive-summary.md** — what the complete solution is, the four-phase lifecycle, the outcome, the

boundary (posture remediation cross-references the CSPM & Secure Score Remediation solution), and effort.

1. **01-solution-overview.md** — what Defender for Cloud is (CSPM + CWPP), how the technology works, the

four phases mapped to the standard deployment model (Assess → Configure → Pilot → Validate → Expand), scope, out of scope, and the connections/authentication used.

1. **02-requirements.md** — the solution-specific prerequisites (MG hierarchy, deployment identity,

providers, plan/cost decisions, Servers agents, export/SIEM, alert tuning + response workflow, pilot subscription for labs, attendee access, multicloud inputs, PoC RG + criteria, change control), each with Description / Why / Verify / Implement-if-missing; references the category-level `global-requirements-defender.md`.

1. **03-implementation.md** — the ordered, click-by-click build across the four phases (Architect →

Protect → Enable the team → Prove value) and Expand, with every object named `<Purpose> – <Scope> – <Stage>` and reused verbatim.

1. **05-testing.md** — per-phase validation with explicit pass/fail gates, including the enablement

knowledge-check and the PoC scorecard gates.

1. **06-troubleshooting.md** — symptom → cause → fix for the common failures across all four phases.
2. **07-best-practices.md** — keep-it-clean guidance and where to go next in the catalog.
3. **08-deliverables-summary.md** — this document.
4. **global-requirements-defender.md** — the category-level prerequisites (published once, referenced by

the requirements guide).

Scripts (scripts/)

Seven consolidated artifacts. PowerShell uses `Az` modules and is **read-only** except the single preview-gated deploy/enable script and the PoC helper; the reference IaC is Bicep; the lab/hunting pack is KQL.

1. **MDCFULL-Discovery.ps1** — read-only estate readiness: MG hierarchy, per-subscription Defender plan

tiers, provider registration, Log Analytics workspaces, AWS/GCP connectors, agent coverage, and resource counts (cost drivers). Writes a JSON snapshot.

1. **MDCFULL-Validate.ps1** — read-only validation across the lifecycle: plans enabled + inheritance,

providers, Servers MDE/agent coverage, continuous export, the notify-only response workflow, and (with `-PoC`) the PoC recommendation/Secure Score/alerts/compliance.

1. **MDCFULL-Report.ps1** — coverage, cost, and alert reporting with a saveable baseline for

drift tracking (`-Mode Coverage|Cost|Alerts`).

1. **main.bicep** — the **reference architecture** skeleton: enables Defender for Cloud plans at

management-group scope (via the built-in plan-configuration policy initiative) so subscriptions inherit protection. Deploy **what-if first**; a reference to adapt, not a blind apply.

1. **MDCFULL-Deploy.ps1** — the only change script: `-WhatIf`**-gated and cost-gated**. Wraps `main.bicep`

as a management-group deployment (`-ManagementGroupId`) and enables workload plans per subscription (`-SubscriptionId -Plans …`) via `Az.Security`. Preview by default; `-Apply` to change.

1. **MDCFULL-LabPack.kql** — the read-only ARG/KQL lab and hunting pack (recommendations by impact,

Secure Score by control, security-alert triage, advanced-hunting alerts, unhealthy-resource drill-down, Secure-Score trend, and the workload-alert validation query). Save the marked queries under the runbook names.

1. **MDCFULL-PoC.ps1** — the guided proof-of-concept helper (`-Action Assess|TestSignal|Scorecard|

Teardown): benign signal only (sample alerts + a benign misconfigured test resource + EICAR), scored against your criteria, with a -WhatIf-gated teardown that disables the paid plan to stop billing.

Package

Delivered as a **Complete Solution Package (PDF + Word + scripts)** — the eight guides compiled to a Word document and PDF, plus all seven scripts (five PowerShell, one Bicep, one KQL) in a single ZIP, yours to keep and reuse on every wave and every project.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

MDCFULL-Deploy.ps1

Purpose: The single configuration-changing helper for the "Microsoft Defender for Cloud" (complete) solution. Two modes, both PREVIEW-FIRST: MG scope (architecture): -ManagementGroupId '<pilotMgId>' [-Wave 1] Wraps the reference main.bicep as a management-group deployment. DEFAULTS TO A WHAT-IF (New-AzManagementGroupDeployment -WhatIf) so you see exactly which plan enablements would happen before anything changes; -Apply performs the deployment. Subscription scope (workload plans): -SubscriptionId '<guid>' -Plans Servers,StorageAccounts,... Previews (default) or, with -Apply, sets the named Defender plans to Standard on the subscription via Az.Security. PAID plans bill while On. Paid plans incur cost — never -Apply until the what-if/preview is reviewed and cost is approved. HOW TO RUN Architecture (MG) — preview then apply: powershell -ExecutionPolicy Bypass -File .\MDCFULL-Deploy.ps1 -ManagementGroupId '<pilotMgId>' -Wave 1 powershell -ExecutionPolicy Bypass -File .\MDCFULL-Deploy.ps1 -ManagementGroupId '<pilotMgId>' -Wave 1 -Apply Workload plans (subscription) — preview then apply: powershell -ExecutionPolicy Bypass -File .\MDCFULL-Deploy.ps1 -SubscriptionId '<guid>' -Plans VirtualMachines,StorageAccounts powershell -ExecutionPolicy Bypass -File .\MDCFULL-Deploy.ps1 -SubscriptionId '<guid>' -Plans VirtualMachines,StorageAccounts -Apply Requires Az.Accounts, Az.Resources, Az.Security and Owner/Contributor+Security Admin at the scope. EXPECTED RESULTS Preview: prints the what-if (MG) or the plan changes that WOULD be made (subscription). Apply: deploys the Bicep / sets the plans to Standard. Validate with MDCFULL-Validate.ps1. Rollback: redeploy with plans=Free / enforcementMode DoNotEnforce (MG), or set plans back to Free (Set-AzSecurityPricing -PricingTier Free) / MDCFULL-PoC.ps1 -Action Teardown. .NOTES White-label. DEFAULTS TO preview/what-if. PAID plans bill on Apply — verify current pricing and the built-in initiative id in your tenant. Pilot scope first; expand in waves. Cost is finance's decision. > [CmdletBinding()] param([string]$ManagementGroupId, [int]$Wave = 1, [string]$Location = 'eastus', [string]$TemplateFile = ".\main.bicep", [string]$SubscriptionId, [ValidateSet('VirtualMachines','Containers','SqlServers','StorageAccounts','KeyVaults','AppServices','Arm','CloudPosture')] [string[]]$Plans, [switch]$Apply)

How to run: Architecture (MG) — preview then apply: powershell -ExecutionPolicy Bypass -File .\MDCFULL-Deploy.ps1 -ManagementGroupId '<pilotMgId>' -Wave 1 powershell -ExecutionPolicy Bypass -File .\MDCFULL-Deploy.ps1 -ManagementGroupId '<pilotMgId>' -Wave 1 -Apply Workload plans (subscription) — preview then apply: powershell -ExecutionPolicy Bypass -File .\MDCFULL-Deploy.ps1 -SubscriptionId '<guid>' -Plans VirtualMachines,StorageAccounts powershell -ExecutionPolicy Bypass -File .\MDCFULL-Deploy.ps1 -SubscriptionId '<guid>' -Plans VirtualMachines,StorageAccounts -Apply Requires Az.Accounts, Az.Resources, Az.Security and Owner/Contributor+Security Admin at the scope. EXPECTED RESULTS Preview: prints the what-if (MG) or the plan changes that WOULD be made (subscription). Apply: deploys the Bicep / sets the plans to Standard. Validate with MDCFULL-Validate.ps1. Rollback: redeploy with plans=Free / enforcementMode DoNotEnforce (MG), or set plans back to Free (Set-AzSecurityPricing -PricingTier Free) / MDCFULL-PoC.ps1 -Action Teardown. .NOTES White-label. DEFAULTS TO preview/what-if. PAID plans bill on Apply — verify current pricing and the built-in initiative id in your tenant. Pilot scope first; expand in waves. Cost is finance's decision. > [CmdletBinding()] param([string]$ManagementGroupId, [int]$Wave = 1, [string]$Location = 'eastus', [string]$TemplateFile = ".\main.bicep", [string]$SubscriptionId, [ValidateSet('VirtualMachines','Containers','SqlServers','StorageAccounts','KeyVaults','AppServices','Arm','CloudPosture')] [string[]]$Plans,

[switch]$Apply)

MDCFULL-Discovery.ps1

Purpose: Read-only discovery for the "Microsoft Defender for Cloud" (complete) solution. Reports, without changing anything: the signed-in Azure context and the running account's rights, the management- group hierarchy, the subscriptions onboarded to Defender for Cloud and their current Defender plan (pricing) state, Microsoft.Security provider registration, Log Analytics workspaces available for continuous export, any AWS/GCP security connectors, and resource counts by type (the cost drivers). The state to confirm — and the cost to estimate — before designing, enabling, or proving. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\MDCFULL-Discovery.ps1 powershell -ExecutionPolicy Bypass -File .\MDCFULL-Discovery.ps1 -SubscriptionId '<pilot sub id>' Requires the Az modules (Az.Accounts, Az.Security, Az.Resources, Az.OperationalInsights). Sign in with Connect-AzAccount first (the script prompts if not connected). Read-only. EXPECTED RESULTS A readiness picture: context, MG hierarchy, subscriptions, per-plan on/off state, providers, workspaces, connectors, and resource counts — plus a JSON snapshot. Makes no changes. .NOTES White-label. Read-only. Reports configuration/identifiers only; makes no changes. Workload plans and Defender CSPM are PAID per resource — pricing/tier facts are indicative; verify current pricing and plan availability in your tenant. > [CmdletBinding()] param([string]$OutputPath = ".\MDCFULL-discovery.json", [string[]]$SubscriptionId)

How to run: powershell -ExecutionPolicy Bypass -File .\MDCFULL-Discovery.ps1 powershell -ExecutionPolicy Bypass -File .\MDCFULL-Discovery.ps1 -SubscriptionId '<pilot sub id>' Requires the Az modules (Az.Accounts, Az.Security, Az.Resources, Az.OperationalInsights). Sign in with Connect-AzAccount first (the script prompts if not connected). Read-only. EXPECTED RESULTS A readiness picture: context, MG hierarchy, subscriptions, per-plan on/off state, providers, workspaces, connectors, and resource counts — plus a JSON snapshot. Makes no changes. .NOTES White-label. Read-only. Reports configuration/identifiers only; makes no changes. Workload plans and Defender CSPM are PAID per resource — pricing/tier facts are indicative; verify current pricing and plan availability in your tenant. > [CmdletBinding()] param([string]$OutputPath = ".\MDCFULL-discovery.json", [string[]]$SubscriptionId)

MDCFULL-LabPack.kql

MDCFULL-PoC.ps1

Purpose: Runs the Phase D proof-of-concept for the "Microsoft Defender for Cloud" (complete) solution on a single pilot subscription, via one -Action switch: -Action Assess : read-only readiness preview (roles, pilot subscription, plan state, candidates). -Action TestSignal : generate BENIGN test signal — (1) guides creation of Defender for Cloud's built-in SAMPLE security alerts; (2) with -DeployTestResource deploys a benign, DELIBERATELY-MISCONFIGURED test storage account (public blob access, NO real data) tagged MDC-PoC-TESTSIGNAL so CSPM raises a recommendation; (3) prints the EICAR test-file steps for a benign Defender-for-Servers alert. NO real attack, real malware, or real data exposure is ever performed. -Action Scorecard : maps observations (recommendation/Secure Score/alert/compliance) to your criteria.json and writes 'MDC PoC Scorecard - Pilot Sub - Validate.json'. -Action Teardown : deletes the benign test resource(s), sets the chosen Defender plan back to Free to STOP BILLING, and reminds you to dismiss sample alerts. -WhatIf-gated. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\MDCFULL-PoC.ps1 -Action Assess powershell -ExecutionPolicy Bypass -File .\MDCFULL-PoC.ps1 -Action TestSignal -ResourceGroup "MDC PoC - Pilot RG - Pilot" -DeployTestResource powershell -ExecutionPolicy Bypass -File .\MDCFULL-PoC.ps1 -Action Scorecard -CriteriaPath .\criteria.json

powershell -ExecutionPolicy Bypass -File .\MDCFULL-PoC.ps1 -Action Teardown -WhatIf powershell -ExecutionPolicy Bypass -File .\MDCFULL-PoC.ps1 -Action Teardown -SubscriptionId <guid> -WorkloadPlan StorageAccounts Requires Az.Accounts (+ Az.Storage/Az.Security/Az.Resources per action). Contributor/Security Admin on the PILOT subscription for TestSignal/Teardown; Security Reader for Assess/Scorecard. EXPECTED RESULTS Assess previews readiness; TestSignal populates benign signal; Scorecard writes the decision artifact; Teardown deletes the test resource and sets the plan to Free (billing stopped). .NOTES White-label. BENIGN signal only (sample alerts + benign misconfig test resource + EICAR) — never real attacks. Disabling the plan at teardown is what STOPS the Defender-for-Cloud billing. Verify current pricing before enabling. Whether the PoC "passed" is the customer's security/compliance decision. > [CmdletBinding(SupportsShouldProcess = $true, ConfirmImpact = 'High')] param([Parameter(Mandatory)] [ValidateSet('Assess','TestSignal','Scorecard','Teardown')] [string]$Action, [string]$SubscriptionId, [string]$ResourceGroup = 'MDC PoC - Pilot RG - Pilot', [string]$Location = 'eastus', [switch]$DeployTestResource, [ValidateSet('VirtualMachines','StorageAccounts','SqlServers','Containers','KeyVaults','AppServices')] [string]$WorkloadPlan = 'StorageAccounts', [string]$Tag = 'MDC-PoC-TESTSIGNAL', [string]$CriteriaPath = '.\criteria.json', [string]$OutFile = 'MDC PoC Scorecard - Pilot Sub - Validate.json', [switch]$DeleteResourceGroup)

How to run: powershell -ExecutionPolicy Bypass -File .\MDCFULL-PoC.ps1 -Action Assess powershell -ExecutionPolicy Bypass -File .\MDCFULL-PoC.ps1 -Action TestSignal -ResourceGroup "MDC PoC - Pilot RG - Pilot" -DeployTestResource powershell -ExecutionPolicy Bypass -File .\MDCFULL-PoC.ps1 -Action Scorecard -CriteriaPath .\criteria.json powershell -ExecutionPolicy Bypass -File .\MDCFULL-PoC.ps1 -Action Teardown -WhatIf powershell -ExecutionPolicy Bypass -File .\MDCFULL-PoC.ps1 -Action Teardown -SubscriptionId <guid> -WorkloadPlan StorageAccounts Requires Az.Accounts (+ Az.Storage/Az.Security/Az.Resources per action). Contributor/Security Admin on the PILOT subscription for TestSignal/Teardown; Security Reader for Assess/Scorecard. EXPECTED RESULTS Assess previews readiness; TestSignal populates benign signal; Scorecard writes the decision artifact; Teardown deletes the test resource and sets the plan to Free (billing stopped). .NOTES White-label. BENIGN signal only (sample alerts + benign misconfig test resource + EICAR) — never real attacks. Disabling the plan at teardown is what STOPS the Defender-for-Cloud billing. Verify current pricing before enabling. Whether the PoC "passed" is the customer's security/compliance decision. > [CmdletBinding(SupportsShouldProcess = $true, ConfirmImpact = 'High')] param([Parameter(Mandatory)] [ValidateSet('Assess','TestSignal','Scorecard','Teardown')] [string]$Action, [string]$SubscriptionId, [string]$ResourceGroup = 'MDC PoC - Pilot RG - Pilot', [string]$Location = 'eastus', [switch]$DeployTestResource, [ValidateSet('VirtualMachines','StorageAccounts','SqlServers','Containers','KeyVaults','AppServices')] [string]$WorkloadPlan = 'StorageAccounts', [string]$Tag = 'MDC-PoC-TESTSIGNAL', [string]$CriteriaPath = '.\criteria.json', [string]$OutFile = 'MDC PoC Scorecard - Pilot Sub - Validate.json', [switch]$DeleteResourceGroup)

MDCFULL-Report.ps1

Purpose: Read-only reporting for the "Microsoft Defender for Cloud" (complete) solution: -Mode Coverage : which plans are On across the scoped subscriptions (coverage picture); with -SaveBaseline records a baseline, and -BaselinePath compares against it. -Mode Cost : counts protected resources per plan (the cost drivers) for an INDICATIVE estimate — pricing is version-dependent; verify current pricing. -Mode Alerts : the current Defender for Cloud security-alert inventory and any suppression posture, so tuning can

be reviewed. Makes no changes — reads state only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\MDCFULL-Report.ps1 -Mode Coverage -SaveBaseline powershell -ExecutionPolicy Bypass -File .\MDCFULL-Report.ps1 -Mode Coverage -BaselinePath .\mdcfull-baseline.json powershell -ExecutionPolicy Bypass -File .\MDCFULL-Report.ps1 -Mode Cost powershell -ExecutionPolicy Bypass -File .\MDCFULL-Report.ps1 -Mode Alerts Requires Az.Accounts, Az.Security, Az.Resources. Sign in first. Read-only. EXPECTED RESULTS A printed report and a JSON artifact (coverage baseline / cost drivers / alert inventory). .NOTES White-label. Read-only. Cost figures are INDICATIVE only — verify current pricing/plan availability. Whether a cost is acceptable is finance's decision; this report only informs it. > [CmdletBinding()] param([ValidateSet('Coverage','Cost','Alerts')] [string]$Mode = 'Coverage', [string[]]$SubscriptionId, [switch]$SaveBaseline, [string]$BaselinePath, [string]$OutputPath = ".\MDCFULL-report.json")

How to run: powershell -ExecutionPolicy Bypass -File .\MDCFULL-Report.ps1 -Mode Coverage -SaveBaseline powershell -ExecutionPolicy Bypass -File .\MDCFULL-Report.ps1 -Mode Coverage -BaselinePath .\mdcfull-baseline.json powershell -ExecutionPolicy Bypass -File .\MDCFULL-Report.ps1 -Mode Cost powershell -ExecutionPolicy Bypass -File .\MDCFULL-Report.ps1 -Mode Alerts Requires Az.Accounts, Az.Security, Az.Resources. Sign in first. Read-only. EXPECTED RESULTS A printed report and a JSON artifact (coverage baseline / cost drivers / alert inventory). .NOTES White-label. Read-only. Cost figures are INDICATIVE only — verify current pricing/plan availability. Whether a cost is acceptable is finance's decision; this report only informs it. > [CmdletBinding()] param([ValidateSet('Coverage','Cost','Alerts')] [string]$Mode = 'Coverage', [string[]]$SubscriptionId, [switch]$SaveBaseline, [string]$BaselinePath, [string]$OutputPath = ".\MDCFULL-report.json")

MDCFULL-Validate.ps1

Purpose: Read-only pass/fail validation for the "Microsoft Defender for Cloud" (complete) solution. Confirms the state the Testing Guide checks, without changing anything: -Plan All : every in-scope workload plan is On on the pilot subscription. -Plan Servers : Defender for Servers MDE integration + monitoring agent coverage. -Plan Export : continuous export configured (data path to the workspace/SIEM). -Plan Workflow : the response workflow exists and is notify-only. -Plan Inherit : plans set at MG scope + a child subscription inherits; providers registered. -PoC : PoC observations — recommendation, Secure Score, alerts, regulatory compliance. With no -Plan/-PoC it runs the readiness set (providers, Secure Score present, a plan on, ARG). HOW TO RUN powershell -ExecutionPolicy Bypass -File .\MDCFULL-Validate.ps1 -SubscriptionId '<pilot sub id>' powershell -ExecutionPolicy Bypass -File .\MDCFULL-Validate.ps1 -Plan All -SubscriptionId '<id>' powershell -ExecutionPolicy Bypass -File .\MDCFULL-Validate.ps1 -PoC -SubscriptionId '<id>' Requires Az.Accounts, Az.Security, Az.Resources (+ Az.ResourceGraph for hunting). Security Reader. EXPECTED RESULTS A checklist of PASS/REVIEW lines for the requested area. Read-only — makes no changes. .NOTES White-label. Read-only. Plan/pricing facts are indicative — verify current pricing/availability. > [CmdletBinding()] param([string]$SubscriptionId, [ValidateSet('All','Servers','Export','Workflow','Inherit')] [string]$Plan, [switch]$PoC, [string]$PilotManagementGroupId)

How to run: powershell -ExecutionPolicy Bypass -File .\MDCFULL-Validate.ps1 -SubscriptionId '<pilot sub id>' powershell -ExecutionPolicy Bypass -File .\MDCFULL-Validate.ps1 -Plan All -SubscriptionId '<id>' powershell -ExecutionPolicy Bypass -File .\MDCFULL-Validate.ps1 -PoC -SubscriptionId '<id>' Requires Az.Accounts, Az.Security, Az.Resources (+ Az.ResourceGraph for hunting). Security Reader. EXPECTED RESULTS A checklist of PASS/REVIEW lines for the requested area. Read-only — makes no changes. .NOTES White-label. Read-only. Plan/pricing facts are indicative — verify current pricing/availability. > [CmdletBinding()] param([string]$SubscriptionId, [ValidateSet('All','Servers','Export','Workflow','Inherit')]

[string]$Plan, [switch]$PoC, [string]$PilotManagementGroupId)

main.bicep

Purpose: // A parameterized, wave-driven skeleton that turns the design record // ('MDC Architecture Decision Record - Platform - Prod') into infrastructure-as-code: it drives the // CSPM plan and the selected workload plans (Servers/Containers/Databases/Storage/KeyVault/AppService) // to Standard at the target management group, via a policy assignment of the built-in Defender-for- // Cloud plan-configuration initiative, so new + existing subscriptions inherit the configuration. // This is a REFERENCE skeleton to review and adapt — not a blind apply. // HOW TO DEPLOY (what-if first) // # Preview at the pilot management group (changes nothing): // az deployment mg what-if --management-group-id <pilotMgId> --location <region> \ // --template-file main.bicep --parameters wave=1 enableDefenderCspm=true // # Apply only after the what-if is reviewed and approved: // az deployment mg create --management-group-id <pilotMgId> --location <region> \ // --template-file main.bicep --parameters wave=1 enableDefenderCspm=true // (MDCFULL-Deploy.ps1 wraps this with a -WhatIf default.) // EXPECTED RESULTS // A management-group policy assignment that drives Defender-for-Cloud plan enablement across // descendant subscriptions, consistent with the wave. Verify with MDCFULL-Validate.ps1 -Plan Inherit. // NOTES // White-label. Deploy what-if first; paid plans incur cost. Verify current plan availability // and the built-in policy/initiative definition ids in your tenant before applying.